

U.S. Healthcare Provider Underwriting Standard

Incentivizing Healthcare Cybersecurity Defense



Meet The Team

Soha Arian



Joyce Nowlin



Brandon Wang

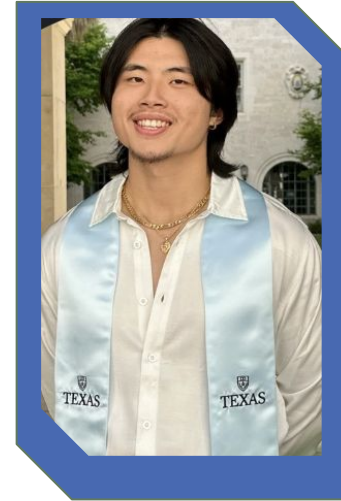


Table Of Contents



01 Problem Statement

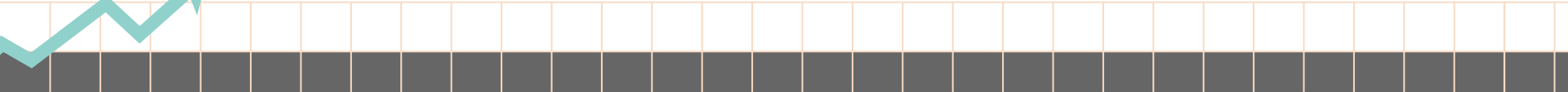
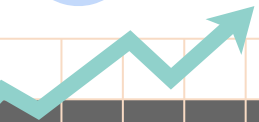
04 Interpretation

02 Research Question

05 Recommendations

03 Key Findings

06 Conclusion



Healthcare Cyber Risk: A Growing & Underserved Challenge

62%

of health systems have
NOT fully implemented
the NIST CSF

2×

increase in cyberattack
costs between
2016–2019

\$9.8M

average cost of a
healthcare data breach
in 2024 (IBM)

The Threat Landscape

Healthcare providers are high-value targets and cyber insurance in healthcare is failing to measure actual risk, making breaches more likely

- Information gap regarding security posture

The Insurance Market Gap

CISA identifies the cyber insurance market as underdeveloped due to:

- Insufficient actuarial data on cyber losses
- Inconsistent analytical methods across insurers
- Premium pricing based on judgment, not empirical risk

The Self-Assessment Questionnaire Problem

Current Questionnaire Reality

- Binary YES / NO questions only
- Controls assessed for existence, not effectiveness
- No testing cadence or evidence requirements
- "Do you have backups?" – doesn't reveal if they're ransomware-resistant or tested
- Inconsistent wording across all insurers



What Underwriting Should Assess

- Maturity-based scoring (0-10 scale)
- Effectiveness, frequency of testing & evidence
- Healthcare-specific risk scenarios (PHI, EHR, IoMT)
- Standardized domains across all insurers
- Clear incentives connecting security posture to premiums

Core Problem: Cyber insurance underwriting forms are convenient, but inadequate.

Primary Research Question

How well do cyber insurance underwriting questionnaires for U.S. healthcare providers match actual healthcare breach patterns and recognized cybersecurity controls?

Secondary:

How can underwriting questions be improved to be more consistent, detailed, and effective for evaluating healthcare cyber risk?

01

Breach Data Analysis

- HHS OCR Breach Portal
- 2016–2025
- 5,184 incidents
- Keyword coding + Plotly AI
- Capture real-world breach patterns

02

Underwriting Form Review

- Deductive content analysis
- 6 PDF forms
- 4 insurers
- (Beazley, Chubb, Coalition, Hartford)
- Evaluate insurer assumptions

03

Risk-Control Matrix

- 14 risk scenarios × 22 controls
- Ordinal mitigation mapping
- Priority tiers: Critical / High / Medium

04

Scoring Framework

- 6-domain weighted questionnaire
- Maturity scale 0–10
- Risk tiers: Lower → Critical

Breach Data Analysis*Thematic Coding & Frequency Counting*

- HHS OCR Breach Portal: 5,184 incidents (2016–2025)
- AI-powered Plotly analysis for automated pattern recognition
- Manual hand-coding to validate breach causes & remediation
- Categories: ransomware, phishing, unauthorized access, theft/loss, error
- Remediation split: training-based vs. technical safeguards

Underwriting Form Analysis*RStudio Deductive Content Analysis*

- 6 PDF forms from 4 major insurers (Beazley, Chubb, Coalition, Hartford)
- 157 question-level units extracted via pdftools & keyword filters
- Deductive codebook with 15 control categories across 8 broad themes
- AI validation: ChatGPT + Gemini cross-checked RStudio coding
- 45 of 157 items flagged for manual review

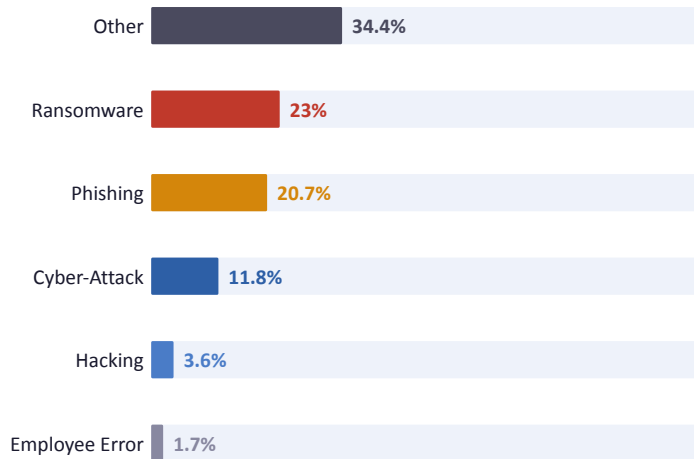
Risk-Control Matrix & Scoring Framework*Domain-Based Risk Scoring*

- 14 healthcare risk scenarios × 22 underwriting controls
- Ordinal scale: Primary (●) · Secondary (◐) · Partial (◑) · None (–)
- Controls tiered: CRITICAL / HIGH / MEDIUM by loss severity
- 6-domain weighted questionnaire (0–10 maturity scale per control)
- 4 output risk tiers: Lower · Moderate · High · Critical

Key Findings: Breach Causes & Keyword Patterns

TOP BREACH CAUSES

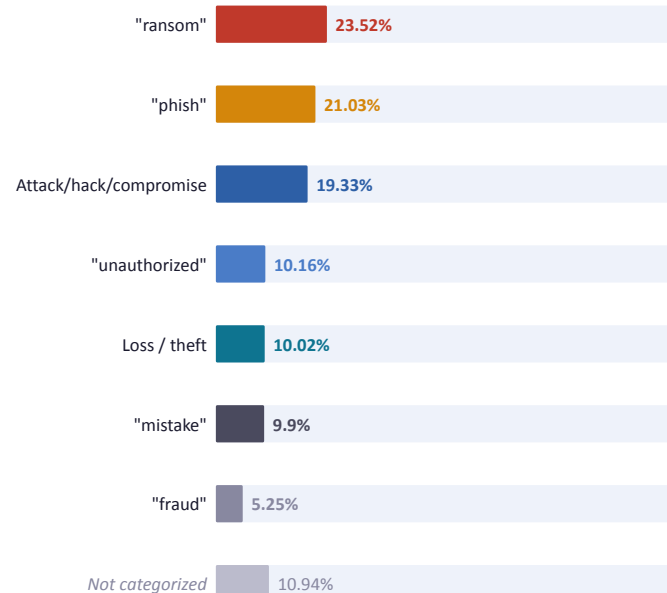
% of incidents (n = 4,764)



Key finding: Ransomware + Phishing alone account for **43.7%** of all breach causes.

KEY BREACH DESCRIPTION KEYWORDS

% of non-null incidents (n = 5,008)

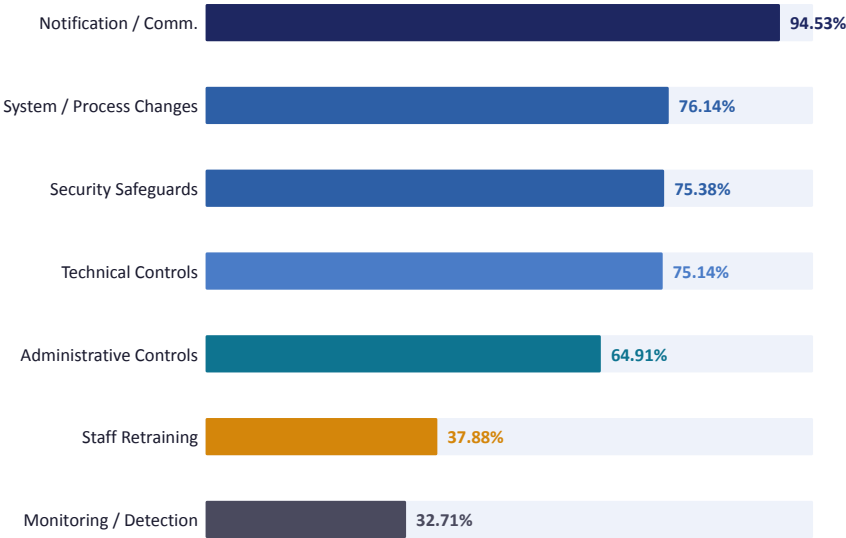


Key finding: Top 3 keywords align with breach causes – confirming ransomware, phishing, and cyber-attacks as dominant threat vectors, though human error is a significant cause as well

Key Findings: Remediation Strategies

TOP REMEDIATION CATEGORIES

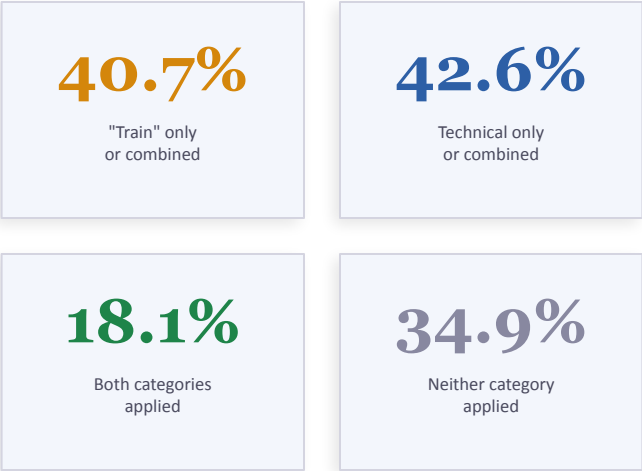
% of incidents (N = 5,008; categories not mutually exclusive)



Key finding: Notification is near-universal (94.5%) due to HIPAA’s Data Breach Notification Rule, while technical and process controls cluster tightly at ~75%, suggesting a broad baseline response pattern.

TRAINING vs. TECHNICAL REMEDIATION

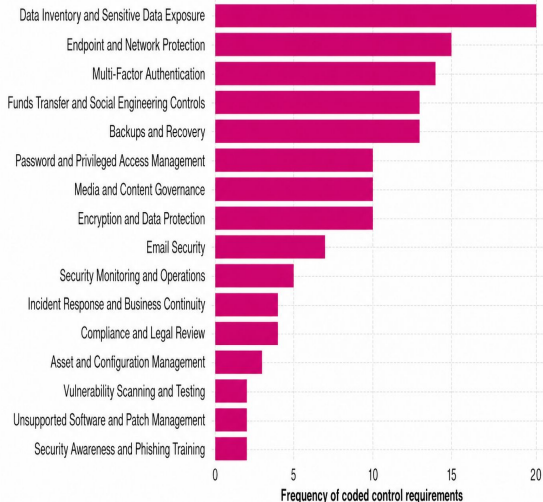
% of non-null incidents (n = 5,008)



OVERLAP BREAKDOWN

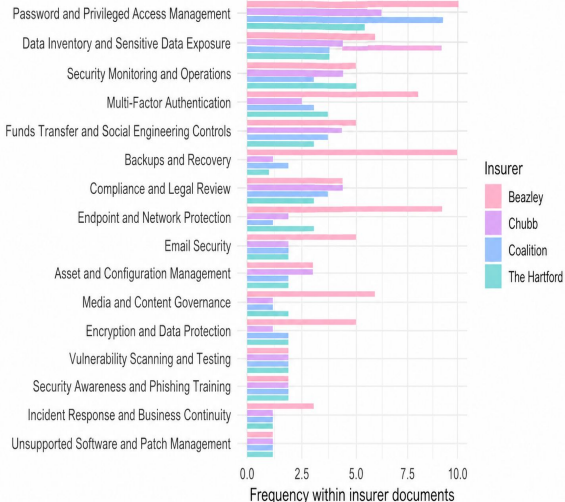


**Qualitative Analysis Graph 1:
Most Frequently Emphasized Control**



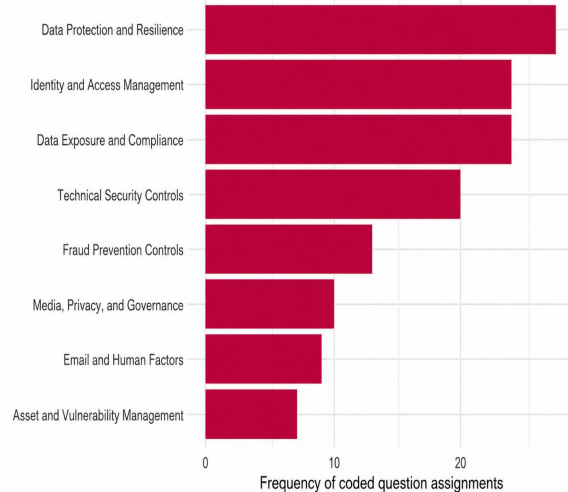
Insurers most strongly prioritize data inventory and sensitive data exposure, followed by endpoint and network protection and multi factor authentication.

**Qualitative Analysis Graph 2:
Control Categories by Insurer**



The results show that underwriting priorities overlap in some areas, but also vary meaningfully across insurer documents.

**Qualitative Analysis Graph 3:
Broad Theme Distribution**



The results indicate greater emphasis on data protection and resilience, identity and access management, and data exposure and compliance.

KEY FINDINGS

Qualitative Analysis: Risk Control Matrix

Control ID	Control	Priority	Ransomware	Phishing / Social Engineering	Credential Theft / BEC	Unauthorized PHI Access	PHI Exfiltration
1.1	MFA	CRITICAL	●	●	●	●	●
1.2	PAM	CRITICAL	●	○	●	●	—
1.3	Periodic Access Recertification	HIGH	○	—	●	●	—
1.4	Offboarding SLA	HIGH	○	—	○	●	—
2.1	Immutable/Air-Gapped Backup	CRITICAL	●	—	—	—	—
2.2	Endpoint Detection & Response (EDR)	CRITICAL	●	●	○	—	○
2.3	Network Segmentation	CRITICAL	●	—	○	○	—
2.4	Clinical Downtime Procedures	HIGH	●	—	—	—	—
3.1	Encryption at rest & In Transit	CRITICAL	○	—	—	○	●
3.2	Data Loss Prevention (DLP)	HIGH	—	○	—	○	●
3.3	Business Associate Agreement (BAA) Monitoring	HIGH	○	—	—	—	●
3.4	Cloud Security Posture (CSPM)	MEDIUM	○	—	—	—	●
4.1	Vendor Risk Mgmt	HIGH	●	—	—	—	●
4.2	Managed Service Provider (MSP) Oversight	CRITICAL	●	—	●	●	—
4.3	Connected Medical Device (IoMT) Security	HIGH	●	—	—	○	—
5.1	HIPAA Annual Risk Analysis	CRITICAL	●	○	○	○	●
5.2	Incident Response Plan	CRITICAL	●	●	○	○	●
5.3	Security Leadership & Board Reporting	MEDIUM	○	—	—	○	—
5.4	Awareness Training & Phishing Simulation	HIGH	●	●	●	○	○
6.1	SIEM / SOC 24x7	HIGH	—	●	●	●	○
6.2	Vulnerability Management & Patching	CRITICAL	●	—	○	○	—
6.3	Electronic Health Record (EHR) Audit Logs	HIGH	○	—	○	●	●

Control ID	Control	Priority	Lost / Stolen Device	Insider Threat	MSP / Supply Chain Compromise	Medical Device (IoMT) Attack	Misconfigured Cloud / Server
1.1	MFA	CRITICAL	—	○	●	—	—
1.2	PAM	CRITICAL	—	●	●	○	○
1.3	Periodic Access Recertification	HIGH	—	●	○	—	—
1.4	Offboarding SLA	HIGH	—	●	●	—	—
2.1	Immutable/Air-Gapped Backup	CRITICAL	—	—	●	○	—
2.2	Endpoint Detection & Response (EDR)	CRITICAL	—	—	●	○	—
2.3	Network Segmentation	CRITICAL	—	—	●	●	○
2.4	Clinical Downtime Procedures	HIGH	—	—	○	●	—
3.1	Encryption at rest & In Transit	CRITICAL	●	○	○	—	●
3.2	Data Loss Prevention (DLP)	HIGH	—	●	○	—	○
3.3	Business Associate Agreement (BAA) Monitoring	HIGH	—	—	●	—	○
3.4	Cloud Security Posture (CSPM)	MEDIUM	—	—	○	—	●
4.1	Vendor Risk Mgmt	HIGH	—	—	●	○	○
4.2	Managed Service Provider (MSP) Oversight	CRITICAL	—	○	●	○	—
4.3	Connected Medical Device (IoMT) Security	HIGH	—	—	○	●	—
5.1	HIPAA Annual Risk Analysis	CRITICAL	○	○	●	●	●
5.2	Incident Response Plan	CRITICAL	—	—	●	●	—
5.3	Security Leadership & Board Reporting	MEDIUM	—	○	○	—	—
5.4	Awareness Training & Phishing Simulation	HIGH	○	○	—	—	—
6.1	SIEM / SOC 24x7	HIGH	—	●	●	○	●
6.2	Vulnerability Management & Patching	CRITICAL	—	—	●	●	●
6.3	Electronic Health Record (EHR) Audit Logs	HIGH	—	●	○	—	—

Control ID	Control	Priority	Regulatory Penalty	HIPAA Breach Notification	Clinical / Patient Safety	Business Interruption
1.1	MFA	CRITICAL	●	●	○	●
1.2	PAM	CRITICAL	●	○	○	●
1.3	Periodic Access Recertification	HIGH	●	●	—	—
1.4	Offboarding SLA	HIGH	●	●	—	—
2.1	Immutable/Air-Gapped Backup	CRITICAL	●	—	●	●
2.2	Endpoint Detection & Response (EDR)	CRITICAL	○	○	●	●
2.3	Network Segmentation	CRITICAL	○	—	●	●
2.4	Clinical Downtime Procedures	HIGH	○	—	●	●
3.1	Encryption at rest & In Transit	CRITICAL	●	●	—	—
3.2	Data Loss Prevention (DLP)	HIGH	●	●	—	—
3.3	Business Associate Agreement (BAA) Monitoring	HIGH	●	●	—	○
3.4	Cloud Security Posture (CSPM)	MEDIUM	●	●	—	○
4.1	Vendor Risk Mgmt	HIGH	●	●	○	●
4.2	Managed Service Provider (MSP) Oversight	CRITICAL	●	○	●	●
4.3	Connected Medical Device (IoMT) Security	HIGH	○	—	●	●
5.1	HIPAA Annual Risk Analysis	CRITICAL	●	●	○	○
5.2	Incident Response Plan	CRITICAL	●	●	●	●
5.3	Security Leadership & Board Reporting	MEDIUM	●	○	○	○
5.4	Awareness Training & Phishing Simulation	HIGH	●	●	○	○
6.1	SIEM / SOC 24x7	HIGH	●	○	●	●
6.2	Vulnerability Management & Patching	CRITICAL	●	○	●	●
6.3	Electronic Health Record (EHR) Audit Logs	HIGH	●	●	—	—

- No single control is able to sufficiently mitigate all risk scenarios so all multi domain assessment is necessary
- MFA and Incident Response Plan demonstrated the broadest mitigation coverage as they appeared as primary or secondary mitigations in greatest number of scenarios: phishing, ransomware, credential theft, unauthorized PHI access, business interruption, and regulatory penalty.
- Immutable/air-gapped backups and network segmentation: strongest primary controls particularly against ransomware and MSP/supply chain compromise.
- DLP and EHR audit logs concentrated most around unauthorized PHI access and exfiltration.



Evidence from Data

- Top breach causes were ransomware and phishing, and remediation types indicate significant human component
- Top coded categories were data inventory, sensitive data exposure, endpoint and network protection, and multi factor authentication.
- All four insurers covered some core controls, but emphasis differed by insurer and category.
- Theme counts clustered around data protection, resilience, identity and access, and data exposure compliance.



Interpretive Claim

- Forms recognize major healthcare cyber risks, but the coverage is uneven across insurers.
- Technical safeguards receive more attention than monitoring, incident response, phishing related human factors, vendor risk, and governance.
- Underwriting forms are not fully reflective of real-world incidents
- The forms measure control presence, rather than control maturity or operational readiness.



Security and Policy Implications

- For insurers: inconsistent forms reduce comparability across applicants and may leave important loss drivers under examined.
- For healthcare providers: different questionnaires create mixed signals about which controls matter most.
- For leaders: results support standardized, maturity based healthcare underwriting tied to real breach patterns.



Overall interpretation

Healthcare underwriting questionnaires **partly align** with real cyber risk, but remain **uneven and incomplete**. They capture important technical safeguards, but give less consistent attention to monitoring, response, human factors, vendor risk, and broader security maturity.

Risk Control Matrix Supports the Underwriting Questionnaire

- Bridges observed breach patterns, best practices, and the scoring framework
- Contextualizes why certain controls appear in the Questionnaire despite omission by current insurers

Focusing on the Human Factor of Security Weakness

- Credential abuse (primary ransomware entry vector)
- Phishing (primary entry mechanism for credential theft)
- 40% human factor as the primary remediation action, yet current insurer underwriting underweights this aspect
- Inclusion of Awareness Training & Phishing Simulation in Questionnaire

Maturity Scale

- Each question has specific & differentiable answer choices
- Allows for more detailed scaled risk scoring

Incentivization

- To support and reward improved security posture over time

Domain	Weight	Rationale
Ransomware Resilience	22%	Largest single driver of healthcare cyber losses
Identity & Access	20%	Primary ransomware entry vector (credential abuse)
Data Protection / PHI	15%	Breach notification cost and OCR penalty exposure
Governance & Compliance	15%	Regulatory amplifier, poor governance multiplies losses
Monitoring & Detection	15%	Dwell time directly drives incident severity
Third-Party / Vendor Risk	13%	MSP and supply chain attacks are growing fast

Primary Deliverable

- Underwriting Questionnaire
 - 6 Weighted Domains
 - Healthcare Specific Risks
 - 22 Questions, Max score of 10
 - Questions reflect maturity levels
 - Labeled CRITICAL/HIGH/MEDIUM
- Tier 1: 75-100 | Tier 2: 55-74 |
Tier 3: 35-54 | Tier 4: 0-34 |

#	Domain	Wt.	Q s	Raw Score (0-N0)	Pct.	Weighted Contrib.	UW Notes
01	Identity & Access Management	20%	4	___ / 40	___%	___	___
02	Ransomware Resilience	22%	4	___ / 40	___%	___	___
03	Data Protection & PHI Controls	15%	4	___ / 40	___%	___	___
04	Third-Party & Vendor Risk	13%	3	___ / 30	___%	___	___
05	Governance & Compliance	15%	4	___ / 40	___%	___	___
06	Monitoring & Detection	15%	3	___ / 30	___%	___	___

Domain 02 | Ransomware Resilience

Weight: 22%

Q 2.1 Backup strategy for EHR and critical clinical systems

CRITICAL

RTO/RPO targets and offline/immutable backup architecture.

■ Online backups only with no offline or immutable copy	0 / 10
■ Offline backups but are untested or infrequent (monthly or greater)	3 / 10
■ Immutable or air-gapped backups, tested quarterly	7 / 10
■ Immutable backups with tested RTO ≤ 4hr / RPO ≤ 1hr, verified monthly	10 / 10

1

Step 1

$$\text{Pct} = \frac{\text{Raw Score}}{\text{Max Score}} \times 100$$

2

Step 2

$$\text{Weighted Contrib} = \text{Pct} \times \text{Weight}$$

3

Step 3

$$\text{Composite} = \sum_{i=1}^6 (\text{Pct}_i \times \text{Wt}_i)$$

4

Step 4

Final Score will fall into Tier 1-4, specific recommendations provided.

Primary Recommendation

For insurers: Adopt a standardized, maturity-based underwriting questionnaire for healthcare providers grounded in observed breach patterns and aligned to HIPAA, NIST CSF, and HHS 405(d).

R1 Replace Binary Forms

- Move from YES/NO to 0–10 maturity scale per control
- Assess implementation, testing cadence, and evidence quality
- Organize questions across 6 standard domains
- Prioritize ransomware & identity domains (heaviest weights)

R2 Require Auditable Evidence

- CRITICAL-tier controls require supporting documentation at binding
- Examples: immutable backup test results, PAM session logs, EDR coverage reports
- Consider third-party attestation for Tier 1 / Tier 2 pricing
- Reduces self-assessment bias and information asymmetry

R3 Build Renewal Incentives

- Renewal-based scoring (not one-time submission)
- Tier 1 status: 5–10% rate reduction on base premium
- Deductible buy-down options for demonstrated improvement
- Non-financial rewards: threat intel feeds, tabletop credits

Future Research:

- Validate control weights using proprietary insurer claims-loss data
- Expand content analysis beyond 4 insurers
- Test whether higher-scoring organizations experience fewer claims, shorter recovery times, and lower claim severity

CONCLUSION

Cyber insurance must become a risk reduction tool — not just risk transfer.

Breach Data Shows:

Ransomware (23.5%) and phishing (21%) dominate healthcare incidents. ~40% of remediations involve staff retraining: cyber risk is not purely technical.

Things to address:

Focus on validating the control weights with proprietary insurer claims-loss data and test if orgs that score higher on the questionnaire truly experience fewer claims, shorter recovery times, and lower claim severity

The Path Forward:

A standardized, maturity-based, 6-domain questionnaire aligned to HIPAA, NIST, and HHS 405(d) provides a defensible foundation for healthcare cyber underwriting.

Proposed Framework

22% Ransomware Resilience

20% Identity & Access

15% Data Protection / PHI

15% Governance & Compliance

15% Monitoring & Detection

13% Third-Party / Vendor Risk

